

Aula 3

Segurança da Informação

Prof. Patrick Landal Athayde

Visão geral de criptografia

Visão geral de criptografia

- A criptografia é a ciência de codificar informações para garantir sua confidencialidade
- A criptografia integra a criptologia, ciência que também abrange a criptoanálise, responsável por quebrar sistemas criptográficos
- Apenas quem possui a chave apropriada pode decifrar o conteúdo original, protegendo comunicações contra interceptações e assegurando integridade e privacidade

Visão geral de criptografia

- Seu uso remonta à Antiguidade, como exemplifica a cifra de César, utilizada por Júlio César, no século I a.C., para proteger mensagens militares
- Com o tempo, os métodos criptográficos evoluíram, sendo, hoje, padronizados por instituições como o *National Institute of Standards and Technology* (NIST).

Criptografia clássica

- Na chamada criptografia clássica, desenvolvida ao longo dos séculos, utilizavam-se métodos manuais ou mecânicos para transformar o texto claro em mensagens cifradas. Exemplos históricos incluem a cifra de César, a cifra de Vigenère e a cifra de Playfair, baseadas em técnicas de substituição ou transposição de caracteres

Criptografia moderna

- No contexto contemporâneo da segurança da informação, os antigos "códigos" foram formalizados como esquemas de criptografia, refletindo o amadurecimento da área com base em fundamentos matemáticos e computacionais

Criptografia simétrica e assimétrica

Criptografia simétrica e assimétrica

- A criptografia é uma ferramenta fundamental para proteger informações em ambientes computacionais, garantindo confidencialidade, integridade, autenticidade e não repúdio. As estratégias criptográficas atuais se baseiam em dois paradigmas principais: a criptografia simétrica, que utiliza uma única chave secreta compartilhada para cifrar e decifrar mensagens, e a criptografia assimétrica, também chamada de chave pública

- Entre os algoritmos mais usados na criptografia simétrica se destacam:
 - AES (*Advanced Encryption Standard*)
 - Triple DES

- Já a criptografia assimétrica utiliza um par de chaves relacionadas, pública e privada, indicada para aplicações que requerem escalabilidade e interoperabilidade:
 - Como em protocolos SSL/TLS
 - Infraestruturas PKI (*Public Key Infrastructure*)
 - Com algoritmos como RSA (*Rivest-Shamir-Adleman*)
 - ECC (*Elliptic Curve Cryptography*)

Criptografia simétrica

- A criptografia simétrica, também chamada de criptografia de chave privada, utiliza uma única chave secreta compartilhada entre remetente e destinatário para cifrar e decifrar mensagens. Essa abordagem é eficiente em termos de processamento, permitindo rápida execução mesmo em dispositivos com capacidade limitada, sendo amplamente usada em armazenamento de dados e sistemas embarcados

Criptografia simétrica

- Seu principal desafio é a distribuição segura da chave secreta, pois o vazamento da chave compromete a confidencialidade da comunicação, frequentemente sem detecção. A entrega segura da chave geralmente exige um canal separado do principal (*out-of-band*), o que limita sua aplicação em sistemas distribuídos ou de grande escala

Criptografia assimétrica

- A criptografia assimétrica, ou de chave pública, baseia-se no uso de um par de chaves matematicamente relacionadas: uma pública, amplamente divulgada, e outra privada, mantida sob sigilo pelo titular. Esse modelo permite que qualquer pessoa cifre uma mensagem usando a chave pública do destinatário, sendo possível decifrá-la apenas com a correspondente chave privada, assegurando confidencialidade e autenticidade

- Durante o desenvolvimento de uma aplicação ou solução, algumas questões devem ser levantadas quanto à satisfação e segurança do cliente:
 - Compreender sua necessidade de segurança
 - Como transformar este anseio em especificação do projeto
 - Como implementar esse sistema de forma segura
 - Como realizar a validação do sistema, para verificar se a solução atende aos requisitos propostos e se atende às necessidades de segurança do cliente

Criptografia híbrida

- A criptografia híbrida é uma estratégia robusta e eficiente que integra as vantagens dos métodos simétrico e assimétrico em um único sistema criptográfico
- Ao combinar a alta velocidade dos algoritmos simétricos com a segurança da criptografia assimétrica, essa abordagem assegura comunicações simultaneamente seguras e de alto desempenho, especialmente em ambientes que lidam com grandes volumes de dados

Criptografia híbrida

- Princípio de funcionamento:
 - Geração de um par de chaves assimétricas (pública e privada)
 - Dados criptografados em uma chave simétrica
 - Chave é cifrada com a chave pública e enviada ao destinatário junto com a mensagem
 - O destinatário utiliza sua chave privada para recuperar a chave simétrica e, com ela, decifrar os dados

Infraestrutura de chaves públicas (PKI) e certificados digitais

Infraestrutura de chaves públicas (PKI) e certificados digitais

- A infraestrutura de chave pública (PKI) é um conjunto estruturado de tecnologias, normas e procedimentos que viabiliza a gestão segura de certificados digitais
- A PKI é composta por componentes lógicos e físicos, destacando-se a Autoridade Certificadora (CA) e a Autoridade de Registro (RA)

O uso da infraestrutura de chave pública na era digital contemporânea

- A trajetória da PKI pode ser dividida em três fases distintas
 - Entre 1995-2002: uso era limitado a certificados de alto valor
 - De 2003 a 2010: a PKI se expandiu no ambiente corporativo
 - A partir de 2011: passou a atender demandas massivas por escalabilidade na emissão e gestão de certificados

Desafios solucionados pela PKI

- Principais atribuições:
 - Segurança de navegação *web* por meio de certificados SSL/TLS
 - Controle de acesso em redes privadas e VPNs, cifração de dados sensíveis
 - Validação de autoria de *softwares* via assinaturas digitais e autenticação em redes *wi-fi* sem uso de senhas convencionais

Desafios solucionados pela PKI

- No contexto IoT:
 - Autentica e protege comunicações de sistemas embarcados, como GPS
 - Assistentes inteligentes e fabricantes de dispositivos médicos, nos quais é exigida pela FDA para validar atualizações seguras e autenticar conexões entre equipamentos e redes clínicas

Limitações da PKI

- Entre elas, destaca-se a latência nos processos de autenticação e transferência de dados, causada pela complexidade matemática dos algoritmos de geração e gerenciamento de chaves
- Outro risco relevante é o comprometimento da chave privada: se obtida por agentes maliciosos, a confidencialidade das comunicações pode ser violada, mesmo com a chave pública amplamente disponível

Assinaturas e certificados digitais

- As assinaturas digitais e os certificados digitais constituem alicerces essenciais para a segurança e a confiança nas atividades *online*
- Esses mecanismos operam com objetivos bem definidos: autenticação, ao assegurar que a identidade do emissor seja legítima; integridade, ao garantir que o conteúdo transmitido não foi alterado durante o percurso; e não-repúdio, ao impedir que o emissor negue posteriormente a autoria da comunicação ou transação

- A assinatura digital é um recurso computacional que assegura a autenticidade e integridade de documentos, combinando um algoritmo de *hash* unidirecional, que gera um resumo fixo do conteúdo, com a cifração desse resumo pela chave privada do emissor
- O certificado digital atua como um “passaporte virtual” que vincula uma chave pública a uma identidade real por meio da validação de uma Autoridade Certificadora (AC) confiável

Criptografia em ações modernas

Criptografia em ações modernas

- A criptografia, antes restrita ao contexto militar e diplomático, tornou-se um pilar estratégico na era digital, desempenhando papel central em questões de soberania, privacidade e segurança
- Atualmente, é indispensável em aplicações como autenticação digital, contratos inteligentes, proteção de dados na nuvem e comunicações seguras em contextos sensíveis

Criptografia como elemento da soberania digital

- A criptografia é uma ferramenta essencial para a afirmação da soberania digital, pois oferece mecanismos de segurança, privacidade e controle sobre os dados em ambientes virtuais
- Conforme Pierucci (2015), a soberania no ciberespaço vai além da regulação, envolvendo a incorporação de estruturas digitais de governança pelos Estados

Criptografia quântica e o futuro da segurança

- Deutsch(1985): aplicação da teoria quântica em sistemas computacionais
- Bennett e Brassard (1984): primeiro protocolo formal (BB84 – utilização de fótons para codificação de *bits*, sem emaranhamento quântico)

Criptografia quântica e o futuro da segurança

- Ekert (1991): protocolo E91 – com emaranhamento quântico na distribuição de chaves
- Bennett, Brassard e Mermin (1992): protocolo BBM92 – simplifica o protocolo E91
- Bennett (1992): protocolo B92 – variação simplificada do BB84

Criptografia em internet das coisas (IoT) e sistemas embarcados

- A internet das coisas (IoT) é um paradigma tecnológico que promove a interconexão de dispositivos físicos aptos a coletar, processar e transmitir dados via internet
- Os sistemas embarcados (SE), conforme Noergaard (2012), são caracterizados por restrições de *hardware* e *software*, apresentando menor capacidade de processamento, consumo energético reduzido e memória limitada

Blockchain e criptografia: fundamentos e aplicações

- A tecnologia *blockchain*, proposta por Satoshi Nakamoto em 2009, surgiu como solução ao problema do “gasto duplo” em transações digitais, eliminando a necessidade de intermediários financeiros por meio de um sistema descentralizado de registros públicos

Blockchain e criptografia: fundamentos e aplicações

- Sua estrutura criptográfica garante a integridade dos dados, tornando possível validar transações sem um agente central
- Gates (2017) e Swan (2015): aplicada em identidade digital, contratos inteligentes, cadeia de suprimentos e governança distribuída

Criptografia na legislação e normas técnicas

Criptografia na legislação e normas técnicas

- Em um cenário globalizado e orientado por dados, sua regulamentação envolve questões de segurança, privacidade, soberania e direitos fundamentais
- Lei Geral de Proteção de Dados (LGPD – Brasil)
- Regulamento Geral sobre a Proteção de Dados (GDPR – União Europeia)
- *Electronics Signatures in Global and National Commerce Act (E-Sign Act – Estados Unidos)*

Fundamentos jurídicos da criptografia e proteção de dados

- Em uma sociedade orientada por dados, a criptografia é essencial para garantir a confidencialidade, integridade e conformidade legal na proteção da privacidade

Fundamentos jurídicos da criptografia e proteção de dados

- LGPD: exige medidas técnicas e administrativas, como a criptografia, para proteger dados pessoais contra acessos não autorizados e incidentes
- GDPR: destaca a criptografia como medida de segurança proporcional ao risco, podendo até dispensar a comunicação de violações, se os dados estiverem protegidos

Normas técnicas aplicadas à criptografia

- Para garantir segurança, interoperabilidade e auditabilidade, a implementação dos mecanismos criptográficos deve estar alinhada a referenciais normativos reconhecidos, que orientem tanto os aspectos técnicos quanto a governança da segurança da informação

- Principais normativas:
- Família ISO/IEC 27000
 - ISO/IEC 27001:2022, que estabelece requisitos para Sistemas de Gestão de Segurança da Informação (SGSI)
 - ISO/IEC 27002:2022, que oferece diretrizes práticas com controles de criptografia para proteger confidencialidade, integridade, autenticidade e não repúdio

- O NIST SP 800-57 Part 1 Rev. 5 fornece recomendações detalhadas para a gestão do ciclo de vida das chaves criptográficas, sendo referência global especialmente em infraestruturas críticas
- Norma brasileira, ABNT NBR ISO/IEC 19790:2021 define requisitos de segurança para módulos criptográficos, incluindo proteção física, autotestes e gestão segura de chaves, indicada para instituições que utilizam *hardware* de segurança, como bancos e autoridades certificadoras

A infraestrutura de chaves públicas e a certificação digital no Brasil

- Em uma sociedade cada vez mais digitalizada, a infraestrutura de chaves públicas (ICP) é fundamental para garantir a confiabilidade, autenticidade e integridade das informações eletrônicas, viabilizando juridicamente as interações digitais, especialmente no setor público e nas relações contratuais

A infraestrutura de chaves públicas e a certificação digital no Brasil

- No Brasil, a ICP-Brasil foi instituída pela Medida Provisória n. 2.200-2/2001, com o objetivo de assegurar autenticidade, integridade e validade jurídica de documentos eletrônicos (Brasil, 2001)

- A Lei n. 14.063/2020 ampliou o uso das assinaturas eletrônicas no setor público, definindo três categorias, simples, avançada e qualificada, sendo esta última vinculada ao certificado digital da ICP-Brasil e a única com validade jurídica plena (Brasil, 2020)